WEB APPLICATION SECURITY AUDIT & BIA REPORT

Target: https://www.amazon.in/

Automated Defensive Posture Assessment | Date: 2026-09-18 22:39:05

Target Infrastructure Profile

Target URL:
https://www.amazon.in/

IP Address: 99.86.150.21

Web Server: Server

Duration: 5.38 seconds

Defensive Posture Score

96.0 **[A+]**

Exceptional defensive hygiene with robust modern controls.

1. Executive Summary & Findings Distribution

CRITICAL	HIGH	MEDIUM	LOW	INFO
0	0	0	2	1
CVSS 9.0-10.0	CVSS 7.0-8.9	CVSS 4.0-6.9	CVSS 0.1-3.9	CVSS 0.0

The security posture assessment for 'https://www.amazon.in/' yielded an overall score of 96.0/100 (Grade: A+). The audit identified 0 Critical, 0 High, 0 Medium, and 2 Low severity findings. The target displays solid baseline defensive controls. Addressing minor header omissions and maintaining regular patch management will uphold defense-in-depth posture.

2. Business Impact Analysis (BIA) & Regulatory Compliance

Impact Vector	Evaluated Risk	Business Consequence & Scope
Confidentiality (CIA)	Low	Risk of unauthorized data interception, session cookie hijacking, or internal server metadata leakage.
Integrity (CIA)	Low	Exposure to clickjacking, malicious script execution (XSS), or unauthorized cross-origin tampering (CORS).
Availability (CIA)	High	Susceptibility to denial-of-service, resource exhaustion, or operational downtime from unpatched software.
Financial Exposure	Low	Low - Standard security operational maintenance required
Brand & Reputation	Low	Low - Posture adheres to modern industry baseline standards

Regulatory Framework	Compliance Status & Applicable Standard
PCI-DSS 4.0	COMPLIANT (Baseline controls satisfied)
HIPAA Security Rule	ADEQUATE (Transmission standards met)
GDPR Art. 32	COMPLIANT (Demonstrates reasonable technical hygiene)

3. Transport Layer & Defensive Controls Audit Details

A. Transport Layer Security (TLS/SSL Architecture & Certificate Audit):

Negotiated Protocol	TLSv1.3 (Preferred Cipher: TLS_AES_128_GCM_SHA256)
Certificate Status	VALID & ACTIVE (121 days remaining)
Validity Window	2026-01-19 00:00:00 UTC to 2027-01-17 23:59:59 UTC
Cryptographic Keys	RSA 2048 bits (Signature Digest: SHA256)
Subject Identity	CN=www.amazon.in
Certificate Issuer	CN=Amazon RSA 2048 M01,O=Amazon,C=US
Alternative Domains	www.amazon.in, www.amazon.co.in, p-y3-www-amazon-in-kalias.amazon.in, origin-www.amazon.in, p-yo-www-amazon-in-kalias.amazon.in, amazon.in (+2 more)

B. HTTP Defensive Headers Audit Summary:

Active Defensive Headers	Strict-Transport-Security, Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Permissions-Policy
Missing Defensive Headers	Referrer-Policy

C. Cookie Security & Session Hygiene:

Cookie Directives	No Set-Cookie directives were issued on the audited page.

4. Detailed Security Findings & Remediation Guide

[LOW] HDR-RP-MISSING: Missing Referrer-Policy Header | CVSS: 3.1

Category: HTTP Defensive Headers (OWASP A05:2021)
Description: The server does not specify a Referrer-Policy.
Impact: Sensitive URLs with session tokens, user IDs, or internal query parameters may leak in the Referer header to external third parties.
Evidence: *Header 'Referrer-Policy' is absent.*
Remediation: Configure 'Referrer-Policy: strict-origin-when-cross-origin' or 'no-referrer'.

[INFO] LEAK-SERVER: Web Server Version Banner Disclosure | CVSS: 0.0

Category: Tech Stack & Vulnerability Exposure (OWASP A05:2021)
Description: The server exposes internal technology metadata via 'server: Server'.
Impact: Facilitates targeted attacker reconnaissance and CVE matching.
Evidence: *server: Server*
Remediation: Mask or suppress the 'server' response header in your web server/application configuration.

[LOW] EXP-ROBOTS-SENSITIVE-PATHS: Sensitive Administrative Paths Disclosed in robots.txt | CVSS: 3.3

Category:	Attack Surface & Information Disclosure (OWASP A05:2021)
Description:	robots.txt discloses sensitive restricted directories: /exec/obidos/account-access-login, /exec/obidos/refer-a-friend-login
Impact:	Aids attackers in reconnaissance by revealing confidential application endpoints.
Evidence:	*Disallowed paths: /exec/obidos/account-access-login, /exec/obidos/refer-a-friend-login*
Remediation:	Do not rely on robots.txt for access control. Enforce proper authentication mechanisms.

5. Strategic Remediation Roadmap & Operational Next Steps

Remediation Milestone	Action Plan & Operational Scope
Phase 1 (Immediate: 24-48 hrs)	Resolve all CRITICAL and HIGH severity findings. Deploy missing HSTS headers, renew expiring SSL certificates, and restrict any exposed repository or config files.
Phase 2 (Short-Term: 1-2 weeks)	Implement a hardened Content-Security-Policy (CSP) to mitigate Cross-Site Scripting (XSS). Ensure all session cookies mandate HttpOnly and SameSite=Lax/Strict.
Phase 3 (Operational Hygiene)	Suppress server technology banners (Server, X-Powered-By). Deploy RFC 9116 security.txt to facilitate ethical vulnerability disclosures, and integrate automated scans into CI/CD pipelines.